Access Control

Objectives

- Define access control and list the four access control models
- Describe logical access control methods
- Explain the different types of physical access control
- Define authentication services

Introduction

- Important foundations in information security
  - Verifying approved users
  - Controlling their access
- This introduces principles and practices of controlling access
  - Terminology
  - Four standard control models
  - Best practices
- Authentication services is also covered in this chapter

What Is Access Control?

- Granting or denying approval to use specific resources
- Information system's mechanism to allow or restrict access to data or devices
- Four standard models
- Specific practices used to enforce access control

Access Control Terminology

- Identification
  - Presenting credentials
  - Example: delivery driver presenting employee badge
- Authentication
  - Checking the credentials
  - Example: examining the delivery driver's badge
- Authorization
  - Granting permission to take action
  - Example: allowing delivery driver to pick up package

Action	Description	Scenario example	Computer process
Identification	Review of credentials	Delivery person shows employee badge	User enters username
Authentication	Validate credentials as genuine	Mia reads badge to determine it is real	User provides password
Authorization	Permission granted for admittance	Mia opens door to allow delivery person in	User authorized to log in
Access	Right given to access specific resources	Delivery person can only retrieve box by door	User allowed to access only specific data

Table 9-1 Basic steps in access control

Access Control Terminology (cont'd.)

- Object
  - Specific resource
  - Example: file or hardware device
- Subject
  - User or process functioning on behalf of a user
  - Example: computer user
- Operation
  - Action taken by the subject over an object
  - Example: deleting a file

Role	Description	Duties	Example
Owner	Person responsible for the information	Determines the level of security needed for the data and delegates security duties as required	Determines that the file SALARY.XLSX can be read only by department managers
Custodian	Individual to whom day-to-day actions have been assigned by the owner	Periodically reviews security settings and maintains records of access by end users	Sets and reviews security settings on SALARY.XLSX
End user	User who accesses information in the course of routine job responsibilities	Follows organization's security guidelines and does not attempt to circumvent security	Opens SALARY.XLSX

Table 9-2 Roles in access control

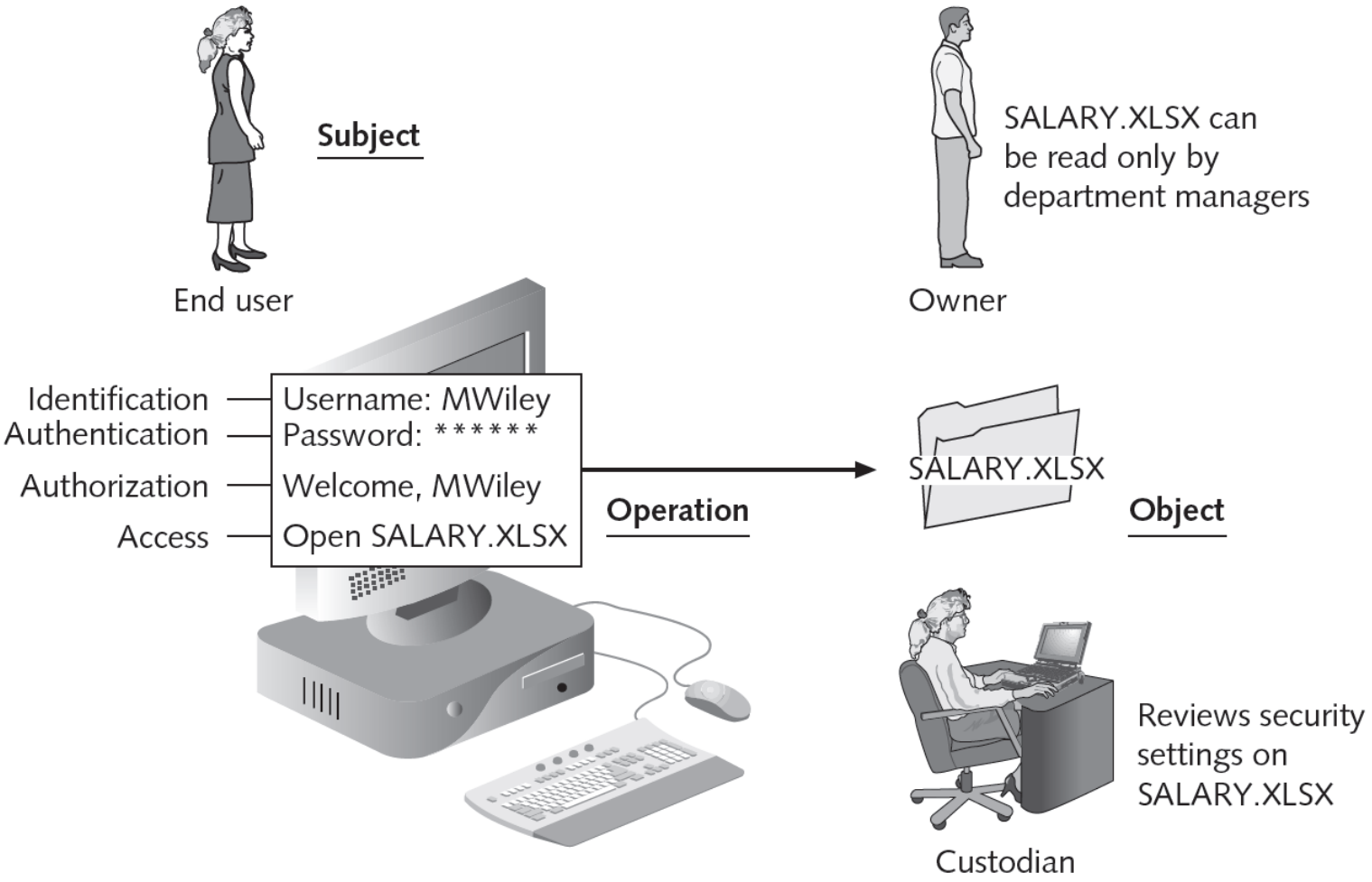


Figure 9-1 Access control process and terminology

© Cengage Learning 2012

Access Control Models

- Standards that provide a predefined framework for hardware or software developers
- Used to implement access control in a device or application
- Custodians can configure security based on owner's requirements
- Four major access control models
  - Mandatory Access Control (MAC)
  - Discretionary Access Control (DAC)

Access Control Models (cont'd.)

- Four major access control models (cont'd.)
  - Role Based Access Control (RBAC)
  - Rule Based Access Control (RBAC)
- Mandatory Access Control
  - Most restrictive access control model
  - Typically found in military settings
  - Two elements
    - Labels
    - Levels

Access Control Models (cont'd.)

- MAC grants permissions by matching object labels with subject labels
  - Labels indicate level of privilege
- To determine if file may be opened:
  - Compare object and subject labels
  - Subject must have equal or greater level than object to be granted access
- Two major implementations of MAC
  - Lattice model
  - Bell-LaPadula model

Access Control Models (cont'd.)

- Lattice model
  - Subjects and objects are assigned a "rung" on the lattice
  - Multiple lattices can be placed beside each other
- Bell-LaPadula
  - Similar to lattice model
  - Subjects may not create a new object or perform specific functions on lower level objects

Access Control Models (cont'd.)

- Example of MAC implementation
  - Windows 7/Vista has four security levels
  - Specific actions by a subject with lower classification require administrator approval
- Discretionary Access Control (DAC)
  - Least restrictive model
  - Every object has an owner
  - Owners have total control over their objects
  - Owners can give permissions to other subjects over their objects

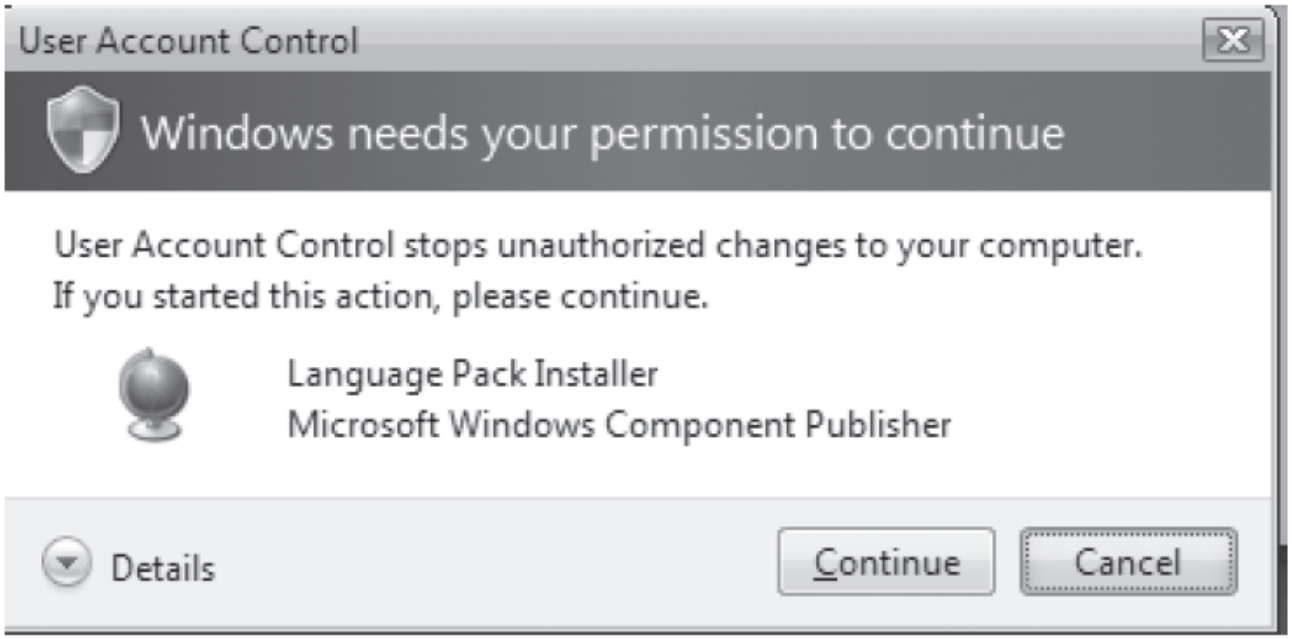


Figure 9-2 Windows User Account Control (UAC) dialog box

© Cengage Learning 2012

Access Control Models (cont'd.)

- Discretionary Access Control (cont'd.)
  - Used on operating systems such as most types of UNIX and Microsoft Windows
- DAC weaknesses
  - Relies on decisions by end user to set proper security level
    - Incorrect permissions may be granted
  - Subject's permissions will be "inherited" by any programs the subject executes
  - Trojans are a particular problem with DAC

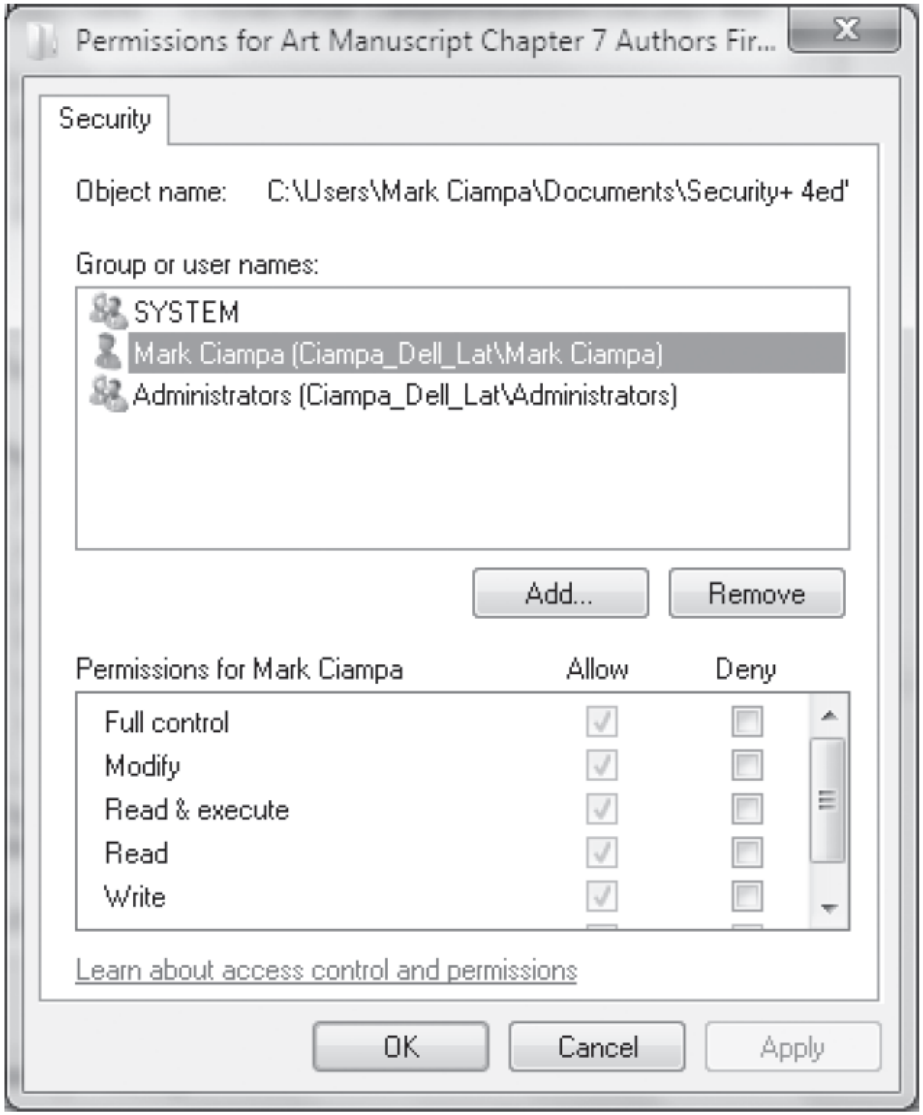


Figure 9-3 Discretionary Access Control (DAC)

© Cengage Learning 2012

Access Control Models (cont'd.)

- Role Based Access Control (RBAC)
  - Also called Non-discretionary Access Control
  - Access permissions are based on user's job function
- RBAC assigns permissions to particular roles in an organization
  - Users are assigned to those roles
- Rule Based Access Control (RBAC)
  - Dynamically assigns roles to subjects based on a set of rules defined by a custodian

Access Control Models (cont'd.)

- Rule Based Access Control (cont'd.)
  - Each resource object contains access properties based on the rules
  - When user attempts access, system checks object's rules to determine access permission
  - Often used for managing user access to one or more systems
    - Business changes may trigger application of the rules specifying access changes

Name	Restrictions	Description
Mandatory Access Control (MAC)	End user cannot set controls	Most restrictive model
Discretionary Access Control (DAC)	Subject has total control over objects	Least restrictive model
Role Based Access Control (RBAC)	Assigns permissions to particular roles in the organization and then users are assigned to roles	Considered a more "real-world" approach
Rule Based Access Control (RBAC)	Dynamically assigns roles to subjects based on a set of rules defined by a custodian	Used for managing user access to one or more systems

Table 9-3 Access control models

Best Practices for Access Control

- Establishing best practices for limiting access
  - Can help secure systems and data
- Examples of best practices
  - Separation of duties
  - Job rotation
  - Least privilege
  - Implicit deny
  - Mandatory vacations

Best Practices for Access Control (cont'd.)

- Separation of duties
  - Fraud can result from single user being trusted with complete control of a process
  - Requiring two or more people responsible for functions related to handling money
  - System is not vulnerable to actions of a single person
- Job rotation
  - Individuals periodically moved between job responsibilities

Best Practices for Access Control (cont'd.)

- Job rotation (cont'd.)
  - Employees can rotate within their department or across departments
- Advantages of job rotation
  - Limits amount of time individuals are in a position to manipulate security configurations
  - Helps expose potential avenues for fraud
    - Individuals have different perspectives and may uncover vulnerabilities
  - Reduces employee burnout

Best Practices for Access Control (cont'd.)

- Least privilege
  - Limiting access to information based on what is needed to perform a job function
  - Helps reduce attack surface by eliminating unnecessary privileges
  - Should apply to users and processes on the system
  - Processes should run at minimum security level needed to correctly function
  - Temptation to assign higher levels of privilege is great

Challenge	Explanation
Legacy applications	Many older software applications were designed to only run with a high level of privilege. Many of these applications were internally developed and are no longer maintained or are third-party applications that are no longer supported. Redeveloping the application may be seen as too costly; an alternative is to run the application in a virtualized environment
Common administrative tasks	In some organizations, basic system administration tasks are performed by the user, such as connecting printers or defragmenting a disk; without a higher level of privilege, users must contact the help desk so that a technician can help with the tasks
Software installation/upgrade	A software update that is not centrally deployed can require a higher privilege level, which can mean support from the local help desk; this usually results in decreased productivity and increased support costs

Table 9-4 Challenges of least privilege

Best Practices for Access Control (cont'd.)

- Implicit deny
  - If a condition is not explicitly met, access request is rejected
  - Example: network router rejects access to all except conditions matching the rule restrictions
- Mandatory vacations
  - Limits fraud, because perpetrator must be present daily to hide fraudulent actions
  - Audit of employee's activities usually scheduled during vacation for sensitive positions

Access Control Lists

- Set of permissions attached to an object
- Specifies which subjects may access the object and what operations they can perform
- When subject requests to perform an operation:
  - System checks ACL for an approved entry
- ACLs usually viewed in relation to operating system files

```
$ setfacl -m user:tdk:rw- samplefile
$ getacl samplefile
# file: samplefile
# owner: reo
# group: sysadmin
user::rw-user:
tdk:rw-              #effective:r--
group::r--           #effective:r--
mask:r--
other:r--
```

Figure 9-4 UNIX file permissions

© Cengage Learning 2012

Access Control Lists (cont'd.)

- Each entry in the ACL table is called access control entry (ACE)
- ACE structure (Windows)
  - Security identifier for the user or group account or logon session
  - Access mask that specifies access rights controlled by ACE
  - Flag that indicates type of ACE
  - Set of flags that determine whether objects can inherit permissions

Group Policies

- Microsoft Windows feature
  - Provides centralized management and configuration of computers and remote users using Active Directory (AD)
  - Usually used in enterprise environments
  - Settings stored in Group Policy Objects (GPOs)
- Local Group Policy
  - Fewer options than a Group Policy
  - Used to configure settings for systems not part of AD

Account Restrictions

- Time of day restrictions
  - Limits the time of day a user may log onto a system
  - Time blocks for permitted access are chosen
  - Can be set on individual systems
- Account expiration
  - Orphaned accounts: accounts that remain active after an employee has left the organization
  - Dormant accounts: not accessed for a lengthy period of time
  - Both can be security risks

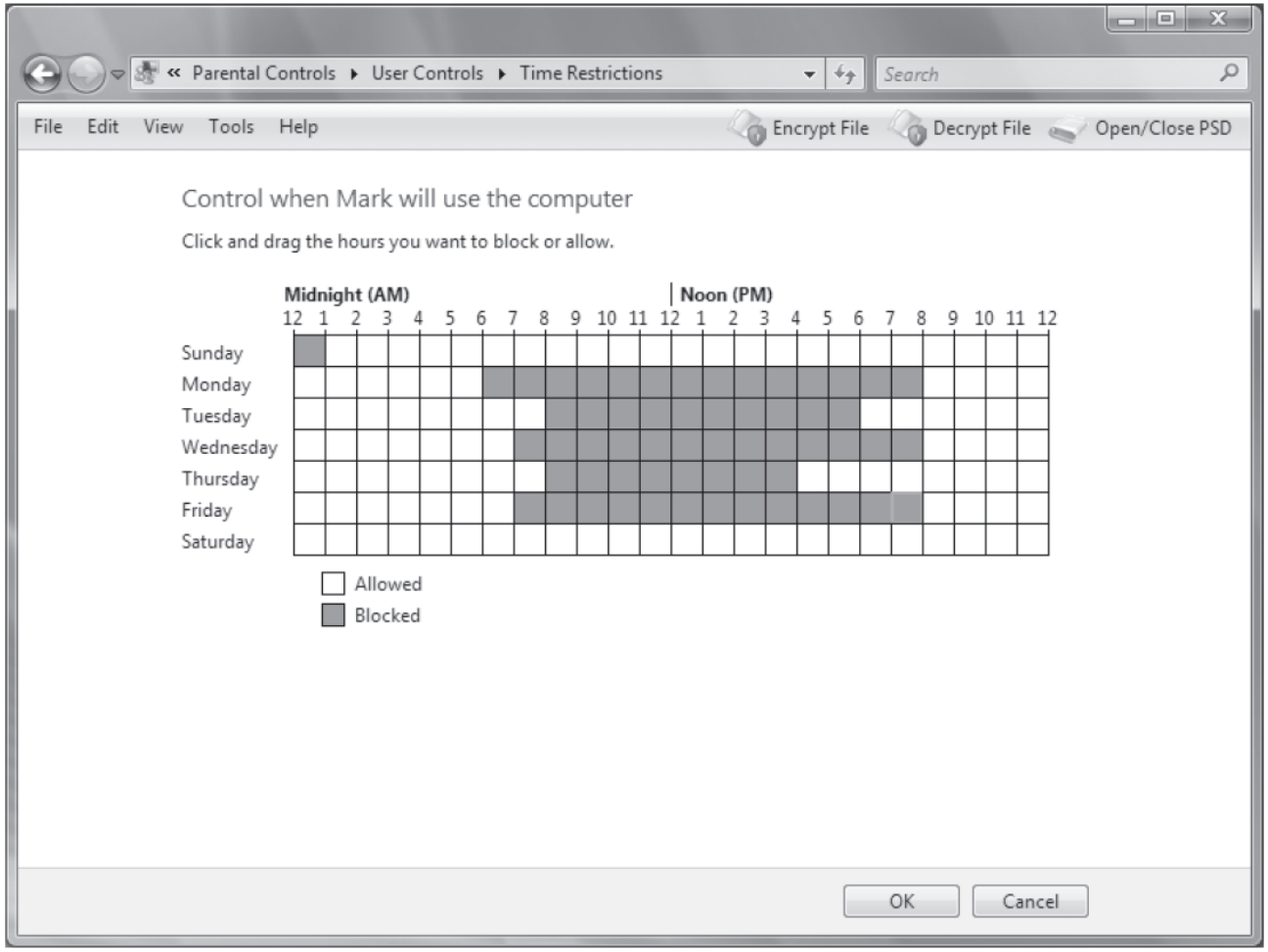


Figure 9-5 Operating system time of day restrictions

© Cengage Learning 2012

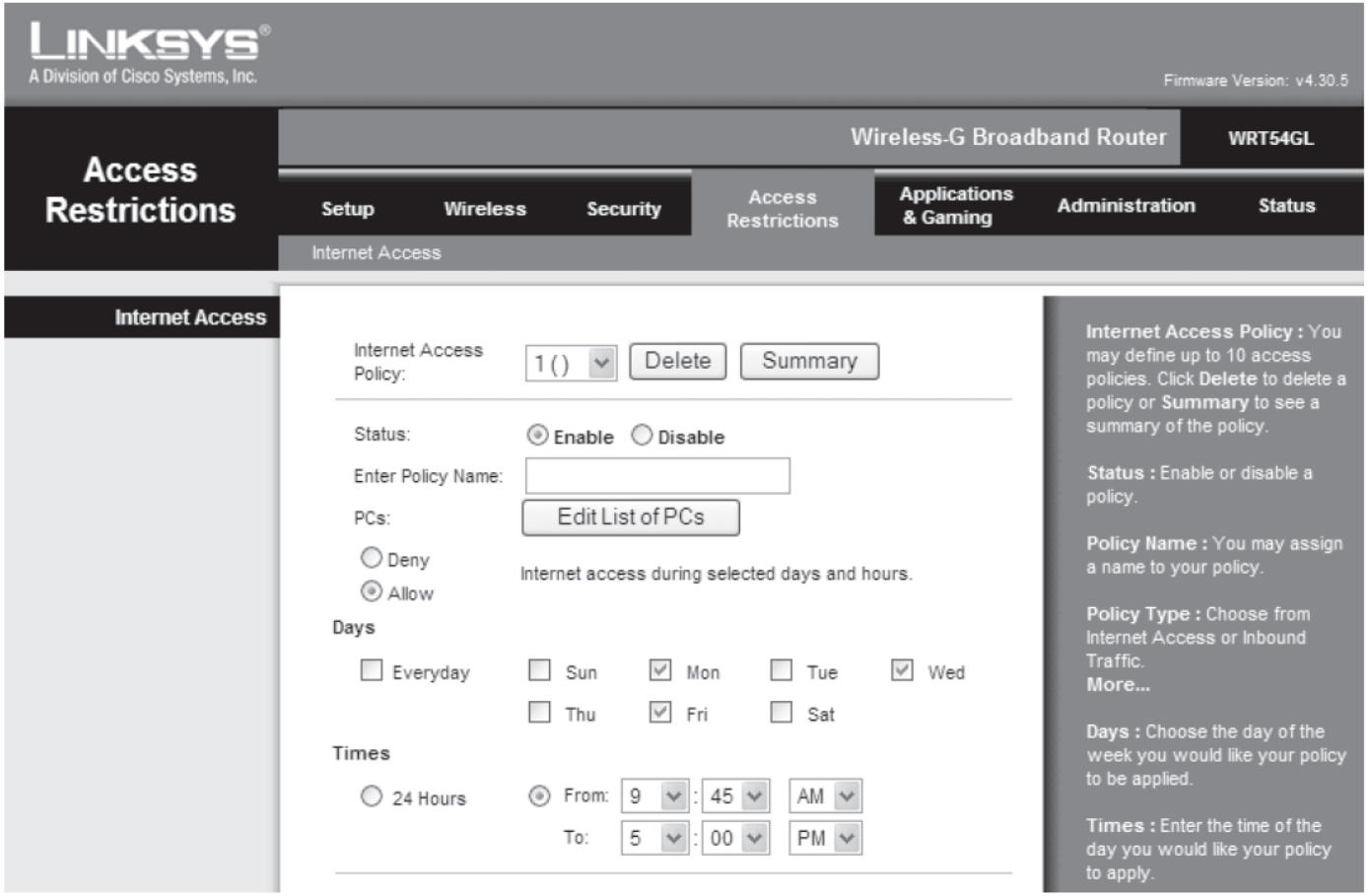


Figure 9-6 Wireless access point restrictions

© Cengage Learning 2012

Account Restrictions (cont'd.)

- Recommendations for dealing with orphaned or dormant accounts
  - Establish a formal process
  - Terminate access immediately
  - Monitor logs
- Orphaned accounts remain a problem in today's organizations
- Account expiration
  - Sets a user's account to expire

Account Restrictions (cont'd.)

- Password expiration sets a time when user must create a new password
  - Different from account expiration
- Account expiration can be a set date, or a number of days of inactivity

Authentication Services

- Authentication
  - Process of verifying credentials
- Authentication services provided on a network
  - Dedicated authentication server
    - Or AAA server if it also performs authorization and accounting
- Common types of authentication and AAA servers
  - Kerberos, RADIUS, TACACS, LDAP

RADIUS

- Remote Authentication Dial In User Service
  - Developed in 1992
  - Became industry standard
  - Suitable for high volume service control applications
    - Such as dial-in access to corporate network
  - Still in use today
- RADIUS client
  - Typically a device such as a wireless AP
    - Responsible for sending user credentials and connection parameters to the RADIUS server

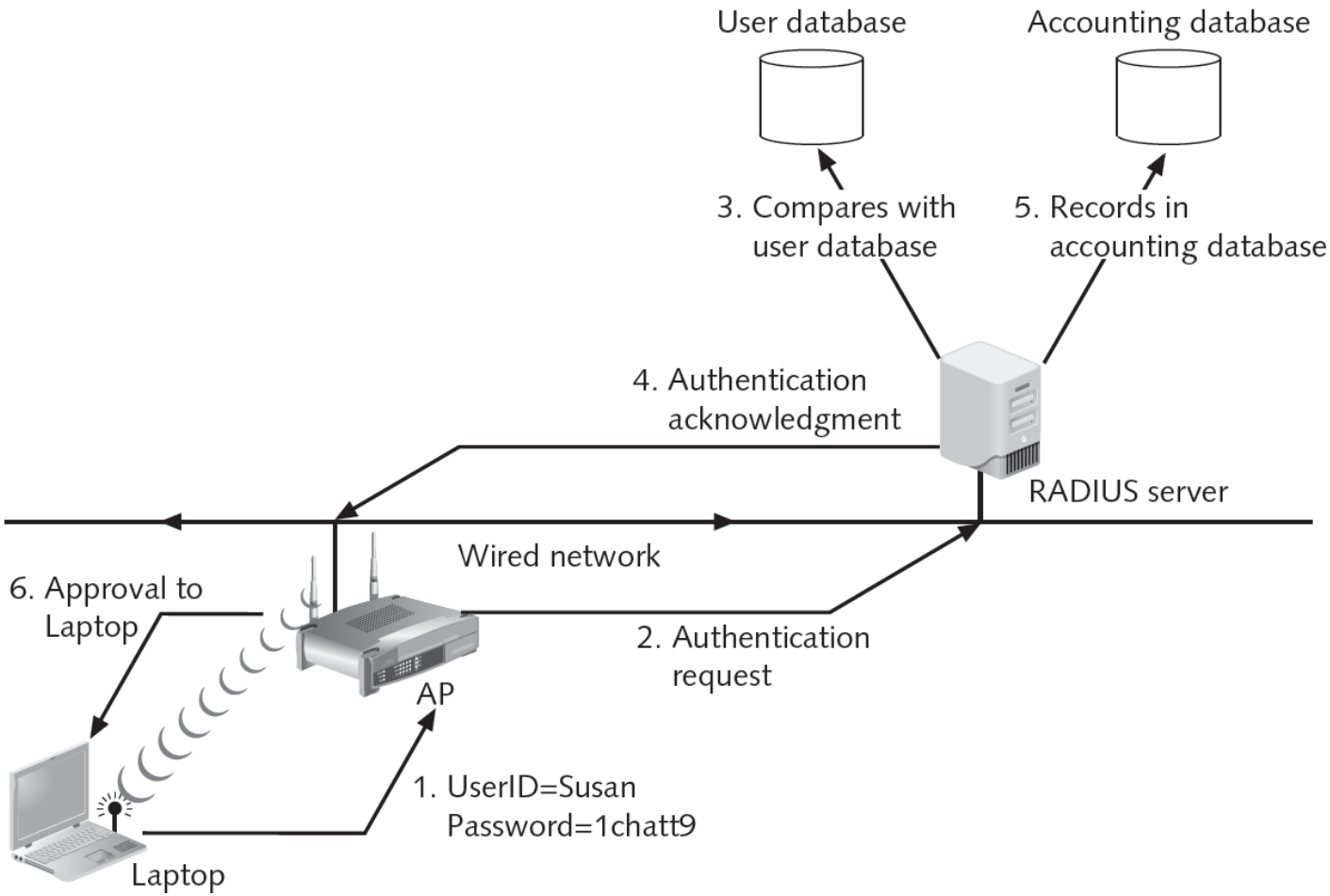


Figure 9-7 RADIUS authentication

© Cengage Learning 2012

RADIUS (cont'd.)

- RADIUS user profiles stored in central database
  - All remote servers can share
- Advantages of a central service
  - Increases security due to a single administered network point
  - Easier to track usage for billing and keeping network statistics

Kerberos

- Authentication system developed at MIT
  - Uses encryption and authentication for security
- Most often used in educational and government settings
- Works like using a driver's license to cash a check
- Kerberos ticket
  - Contains information linking it to the user
  - User presents ticket to network for a service
  - Difficult to copy
  - Expires after a few hours or a day

Terminal Access Control Access Control System (TACACS)

- Authentication service similar to RADIUS
- Developed by Cisco Systems
- Commonly used on UNIX devices
- Communicates by forwarding user authentication information to a centralized server

Feature	RADIUS	TACACS+
Transport protocol	User Datagram Protocol (UDP)	Transmission Control Protocol (TCP)
Authentication and authorization	Combined	Separated
Communication	Unencrypted	Encrypted
Interacts with Kerberos	No	Yes
Can authenticate network devices	No	Yes

Table 9-5 Comparison of RADIUS and TACACS+

Lightweight Directory Access Protocol (LDAP)

- Directory service
  - Database stored on a network
  - Contains information about users and network devices
  - Keeps track of network resources and user's privileges to those resources
  - Grants or denies access based on its information
- Standard for directory services
  - X.500

Lightweight Directory Access Protocol (cont'd.)

- X.500 standard defines protocol for client application to access the DAP
- LDAP
  - A simpler subset of DAP
  - Designed to run over TCP/IP
  - Has simpler functions
  - Encodes protocol elements in simpler way than X.500
  - An open protocol

Lightweight Directory Access Protocol (cont'd.)

- Weakness of LDAP
  - Can be subject to LDAP injection attacks
    - Similar to SQL injection attacks
    - Occurs when user input is not properly filtered

Summary

- Access control is the process by which resources or services are denied or granted
- Four major access control models exist
- Best practices for implementing access control
  - Separation of duties
  - Job rotation
  - Least privilege
  - Mandatory vacations

Summary (cont'd.)

- Access control lists define which subjects are allowed to access which objects
  - Specify which operations they may perform
- Group Policy is a Windows feature that provides centralized management and configuration
- Authentication services can be provided on a network by a dedicated AAA or authentication server
  - RADIUS is the industry standard

- The End!!!